MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 048 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

PLATFORM SPOTLIGHT · AI & COMPLIANCE

CMMC MCP Server: Ask Your AI for an SPRS Score or a STIG Rule

A CMMC MCP server makes your AI look up SPRS weights, STIG rules, and award data instead of guessing. Three no-account MacTech servers, tested live.

BY **PATRICK CARUSO** READING TIME · 7 MIN CMMC · MCP · AI-AUTOMATION · STIG · SAM-GOV

Picture a program manager on a Thursday afternoon typing a reasonable question into a general-purpose chatbot: our file shares are encrypted, but the module isn't FIPS-validated, so what does 3.13.11 cost us in SPRS? The answer comes back fluent, formatted, and possibly wrong in any of three ways. It may recall the wrong weight, miss the sliding scale that applies to exactly this control, or quietly answer from NIST SP 800-171 Rev 3, whose requirement 03.13.11 is a different requirement that DoD does not score at all. Nothing in the reply tells the reader which. That is the case for a CMMC MCP server: the model stops reciting and starts looking things up.

The Model Context Protocol is the plug that lets an AI assistant call outside tools mid-conversation. MacTech Solutions runs three public MCP servers - CMMC and NIST 800-171, DISA STIG, and federal market data - at www.mactechsolutionsllc.com/api/mcp, /api/mcp/stig, and /api/mcp/market. They are listed in the official MCP registry as com.mactechsolutionsllc.www/cmmc, /stig, and /federal-market, and none of them requires an account. Connect one to Claude, Cursor, VS Code, or any MCP client and the numbers in the answer come from a reference corpus rather than from the model's memory. Setup instructions for each client live on the MCP page.

The difference is not intelligence. It is provenance. A model recalling SPRS weights has no way to check itself; a server holding the DoD Assessment Methodology does, because the Rev 2 weights must sum to a 313-point deduction pool, and 110 minus 313 is the -203 floor. MacZine put each server through a real question to see what comes back.

FIELD COPY
ISSUE Nº 048
CMMC

313

POINTS IN THE REV 2 DEDUCTION POOL - THE CHECKSUM BEHIND A SPRS RANGE OF -203 TO 110

24

TOOLS ACROSS MACTECH'S THREE PUBLIC MCP SERVERS - 13 CMMC, 4 STIG, 7 FEDERAL MARKET

2,029

DISA STIG RULES ACROSS 15 BENCHMARKS, EACH WITH CHECK TEXT, FIX TEXT, AND A CCI MAPPING

What does missing FIPS crypto do to my SPRS score?

The CMMC server answered the Thursday question without improvising. Asked for 3.13.11, it returned the requirement text - employ FIPS-validated cryptography when used to protect the confidentiality of CUI - with a weight of 5 and the sliding-scale rule that most recollections drop: subtract 5 if encryption is not employed at all, 3 if it is employed but not FIPS-validated.

Then the arithmetic. With every other requirement implemented and 3.13.11 missing outright, the SPRS score calculator returned 105. Marked partially implemented, meaning encryption in place but unvalidated, it returned 107. Both clear the 88-point line for conditional Level 2 status, and the server flagged that in its response, along with the caveat a spreadsheet would not volunteer: 88 only supports conditional certification when every open item is POA&M-eligible. The regulation behind that caveat is strict - under 32 CFR 170.21 nothing worth more than 1 point may sit on a POA&M - and it makes exactly one exception, which is the second case above: encryption in place but not FIPS-validated. MacZine walked through what a POA&M can and cannot carry. The full logic behind those numbers is in MacZine's SPRS score explainer.

The more telling test was a deliberate mistake. Handed the Rev 3 identifier 03.13.11 to score, the server refused, and said why: there is no DoD Assessment Methodology for Rev 3, and applying Rev 2 weights to it would produce a number that looks like a SPRS score and is not one.

The most valuable thing a compliance tool can do is refuse to hand you a plausible number it cannot stand behind.

That refusal is a design decision, not a gap. DFARS 252.204-7012 remains pinned to Rev 2 by class deviation, and SPRS accepts Rev 2 scores, a fact unchanged by the suspension of CMMC Phase II assessments this summer. The server still serves Rev 3, as advisory reading: a separate lookup returns the Rev 3 requirement and a crosswalk tool explains that both revisions have a requirement at 3.13.11 that are not the same requirement. Around that core sit the 320 NIST 800-171A assessment objectives, crosswalks to 800-53 and FedRAMP Moderate, CSF 2.0, and SOC 2, CMMC level determination, scoping, POA&M generation, and clause lookups for FAR 52.204-21 and DFARS 7012, 7019, 7020, and 7021.

How do I stop SSH from accepting blank passwords on RHEL 9?

A DISA STIG checklist generator is only as good as the rule text inside it, so the second test went to the STIG MCP server. A search for SSH rules on RHEL 9 at high severity returned six CAT I rules from the RHEL 9 STIG v2r6. The first, SV-257984r1045026_rule, is titled "RHEL 9 SSHD must not allow blank passwords," mapped to CCI-000766 and marked SCAP-automatable.

The detail repays the lookup. The check text dumps the effective sshd configuration and greps for PermitEmptyPasswords, and it counts the setting as a finding if it is set to yes, missing, or commented out. That last clause matters: a model answering from general knowledge might reassure you that OpenSSH already defaults to no. The STIG does not accept a default nobody wrote down. The fix text is equally concrete - set PermitEmptyPasswords no in /etc/ssh/sshd_config or a file under sshd_config.d, then restart sshd.

The server then did the part that turns reading into evidence. Asked to export a CAT I-only checklist for RHEL 9 with that one rule recorded as passing, it produced a DISA .ckl file of 20 rules: one NotAFinding and 19 Not_Reviewed. It will not mark a rule as passing that nobody checked, and said so. Coverage is 2,029 rules across 15 benchmarks, including RHEL 8 and 9, Ubuntu 22.04, Windows 11, Windows Server 2022, and Cisco IOS, NX-OS, and ISE. Why that checklist doubles as baseline evidence for 3.4.1 and 3.4.2 is argued in MacZine's piece on what counts as a configuration baseline.

Who is actually buying CMMC work at DoD?

The third server faces outward. The federal market server pairs SAM.gov opportunity and entity lookups with USASpending award history, and the two halves are metered differently. USASpending tools need no key. SAM.gov tools work best with the caller's own free SAM.gov API key, passed as a header or argument; without one, calls draw on a limited shared budget with cached responses. A SAM.gov MCP that promised unlimited free searches would be promising someone else's quota.

MacZine ran a small USASpending query: Department of Defense awards matching the keyword CMMC, five results. The top hit was a roughly $2.0 million Army delivery order that began in June 2026 to procure a turnkey CMMC solution. Two more were Navy orders where CMMC stood for Cruise Missile Material Certification, a reminder that keyword search is literal and a model should read the description before drawing a conclusion. The remaining two were the most instructive: a Navy order for MK 152 foam cushions that added the CMMC requirement clause, and an option-year task order that incorporated CMMC level requirements under DFARS 252.204-7021. The clause is reaching contracts that have nothing to do with IT, which is exactly the signal a small supplier's BD lead should be watching.

What a CMMC MCP server cannot know about your network

Every answer above is reference data plus arithmetic. The score of 105 is only as true as the implementation state someone typed in; the server has never seen your tenant, your SSP, or your firewall. The STIG corpus is current as published, and DISA revises benchmarks on its own schedule, so a rule ID should be checked against the benchmark version the server lists. Market results are only as fresh as SAM.gov and USASpending themselves. None of it substitutes for an assessment.

Two operational cautions follow. The hosted servers state that they store no request or response payloads, keeping only daily aggregate counts of connections, tools called, and client names, but a hosted server is still commercial cloud, so describe your gaps by control number and keep CUI out of the prompt. And where the assistant itself runs inside the boundary, the offline build carries the CMMC and STIG servers with no network at all.

What the servers do offer is a habit worth demanding of any AI in a compliance workflow: every response in these tests closed by naming its source, whether the DoD Assessment Methodology, DISA's XCCDF benchmarks, or the SAM.gov and USASpending APIs. The servers sit alongside the rest of MacTech's free

◆ FOR THE ENCLAVE THAT CANNOT CALL OUT

The hosted servers run in commercial cloud, which a CUI enclave or an air-gapped network should not be reaching. The offline build compiles the CMMC and STIG corpora - not the market tools - into a single 6.7 MB file that runs under Node 20 over stdio, with a published SHA-256 checksum to verify before it crosses the boundary. It is also on npm as mactech-compliance-mcp, and the plugin source is public at github.com/MacTech-Solutions-LLC/mactech-mcp.

tooling on the tools page. A chatbot that guesses is a liability dressed as a productivity gain. One that looks it up, shows the source, and declines to invent a Rev 3 score is closer to a colleague who knows where the binder is. ◆

MORE ISSUES

mactechsolutionsllc.com/maczine

new field copies with every merge

WORK WITH US

CMMC readiness · CUI enclaves · RMF

mactechsolutionsllc.com/contact

MACZINE

Written, reviewed and versioned in the open.

Published from Git, reviewed like code.